

Sécurité du Web et du Code – 4IRC CPE Lyon 2026-2027

Présentation du module (majeures informatique & robotique)

Objectifs pédagogiques

- Implémenter des mécanismes d'authentification robustes
- Appliquer les concepts de sécurité des API et des sessions
- Identifier et corriger les failles de sécurité courantes comme celles décrites par l'OWASP Top 10
- Configurer les en-têtes de sécurité pour les applications web
- Intégrer les bonnes pratiques de sécurité tout au long du cycle de développement logiciel
- Communiquer efficacement sur les vulnérabilités et les risques de sécurité

Planning des séances

Semaine	Lundi	Mardi	Mercredi	Jeudi	Vendredi
39 (sept.)		#1 22/09 AM Authentification	#2 23/09 PM Authentification		#3 25/09 AM Applications Web
41 (oct.)		#4 06/10 PM Applications Web	#5 07/10 PM Applications Web		#6 09/10 AM Applications Web
43 (oct.)		#7 20/10 AM Applications Web	#8 21/10 PM Autonomie		#9 23/10 AM Qualité du code
Vacances de Toussaint					
46 (nov.)	#10 09/11 PM Projet Forensic				#11 13/11 AM Projet Forensic
48 (nov.)	#12 23/11 AM Autonomie #13 23/11 PM Soutenances Projet Forensic				
50 (déc.)			#14 08/12 AM Partiel 1 ^{ère} session		

Contenu du module

Le module se découpe en deux grandes parties.

La première partie se présente en cours/TP (8 séances encadrées et 1 séance d'autonomie) :

- Introduction à l'authentification (2 séances)
 - Identification, Authentification, Autorisation
 - JWTs : structure, utilisation, bonnes pratiques
 - Authentification multifactorielle MFA (OTP, Webauthn, biométrie, ...)
 - Stratégies d'authentification (Single Sign-On, OAuth2, OpenID Connect, ...)
 - Prise en main et utilisation de Keycloak
- Sécurisation des applications web (5 séances)
 - Étude des principales failles de sécurité (OWASP Top 10) : Broken Access Controls, mauvaises configurations de sécurité, injections (SQL, XSS, commandes, prompts), Race Conditions, Pseudo-Aléatoire, Path Traversals, Sandwich Attacks, Informations Disclosures, Prototype Pollution, ...
 - Gestion des cookies et des en-têtes de sécurité
 - Application de la cryptographie au développement web
 - Techniques de prévention et de correction de code
- Qualité du code (1 séance)
 - Principes de Clean Code pour la sécurité
 - Outils d'analyse statique et dynamique de code (SAST et DAST)
 - Gestion des dépendances contre les supply-chain attack
 - Méthodes de stockage des secrets dans le code

La seconde partie se présente en projet de synthèse autour d'une investigation Forensic web (2 séances encadrées et 1 séance d'autonomie).

Modalités d'évaluation

- Séances de cours/TP
 - Challenges type CTF réalisés pendant les séances de cours/TP
 - Challenges non-bonus : tous doivent être résolus pour valider le module (au plus tard le jour de l'examen écrit)
 - Challenges bonus : + 0,1 point sur la note individuelle de projet par challenge bonus résolu (au plus tard le jour de l'examen écrit)
- Projet Forensic web de synthèse
 - En groupe de 3 étudiants
 - Comptabilisé pour 60% de la note finale
 - Évaluation en soutenance orale (30 minutes) – au plus tard le jour de la soutenance :
 - support de présentation et synthèse technique à déposer sur CPe-Campus
 - code-source corrigé à déposer sur GitHub
- Examen écrit
 - Individuel d'une heure sur CPe-Campus, documents interdits
 - Comptabilisé pour 40% de la note finale
 - 30 questions de QCM (10 points)
+ 5 questions ouvertes sur une étude de cas (10 points)